



IPB University
— Bogor Indonesia —



IMPLEMENTASI KEAMANAN INFORMASI

Pengembangan Website Lost & Found NEMU IPB

K2 – Kelompok 7



Marsya Hasna K.
G6401231015



Salma Putri H.
G6401231010



Lathiifa Zahira Y.
G6401231154





Latar Belakang

Transformasi digital di lingkungan IPB mendorong kebutuhan **sistem lost and found yang mampu mengelola laporan barang hilang dan ditemukan secara cepat**, terdokumentasi, dan dapat diaudit. Sistem ini menangani data pengguna, laporan kehilangan dan penemuan, klaim, verifikasi, notifikasi, activity log, dan dokumen serah terima, sehingga aspek **keamanan informasi** menjadi penting. Risiko yang diperhatikan meliputi akses tidak sah, manipulasi laporan atau klaim, kebocoran data, dan perubahan aktivitas tanpa jejak. Dengan prinsip confidentiality, integrity, dan availability serta pendekatan **Authentication, Authorization, dan Accounting (AAA)**, NEMU IPB melindungi data pengguna dan dokumen, membatasi hak akses berbasis role, mencatat aktivitas penting, dan memastikan integritas dokumen melalui hashing dan digital signature.

Fitur Utama

Token Validation

Role Authorization

Password Hashing

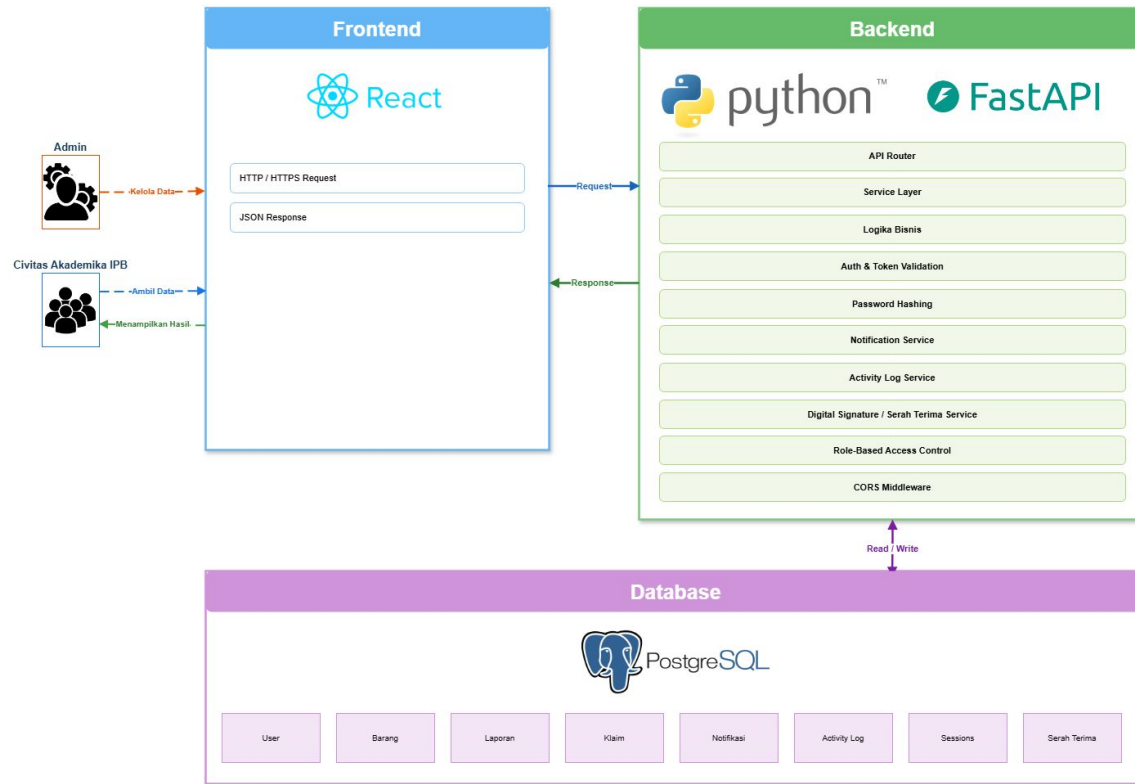
Secure
Communication

Audit Trail

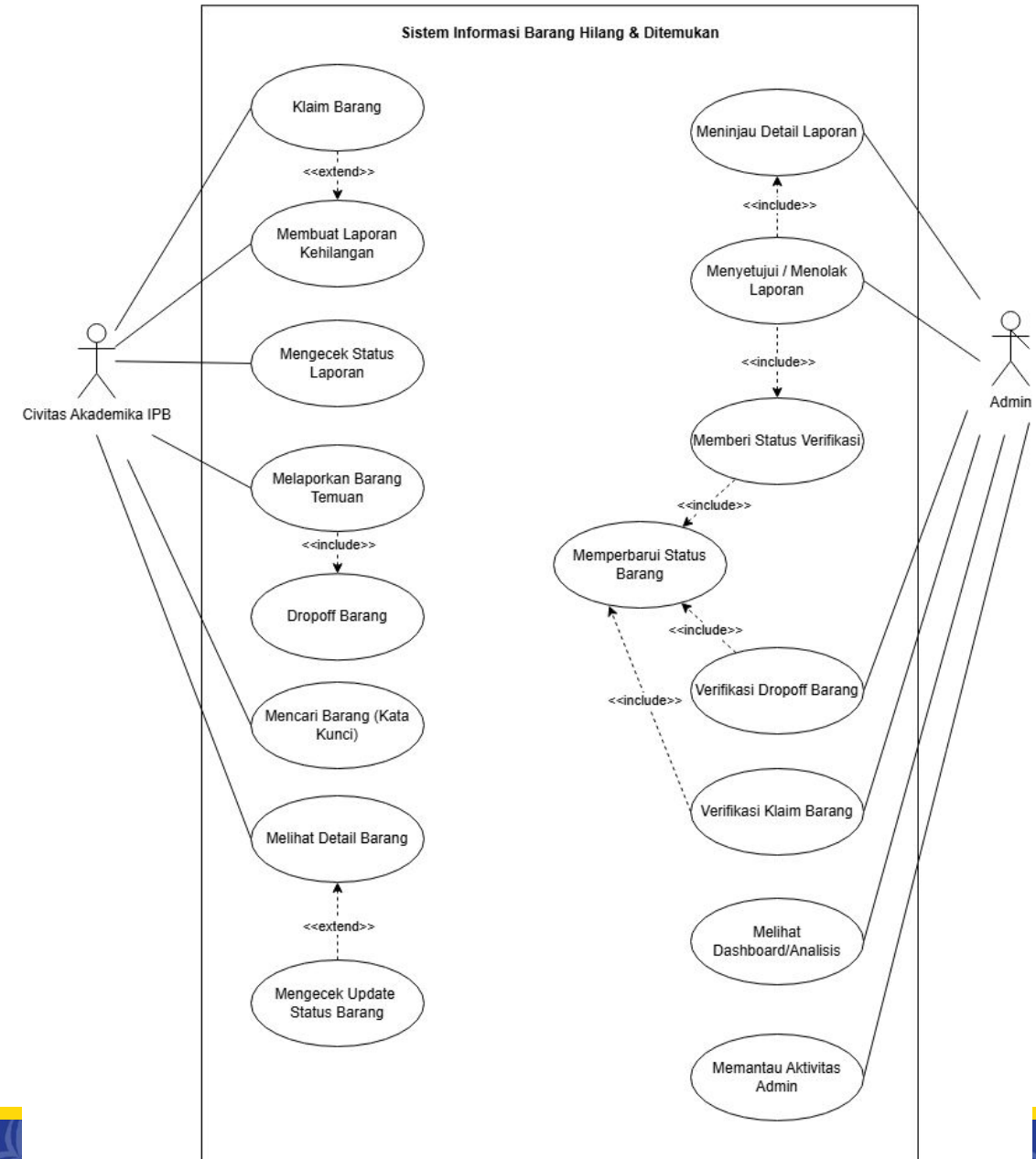


Gambaran Sistem

Web Application Architecture — NEMU IPB



Use Case Diagram



Threat Modelling



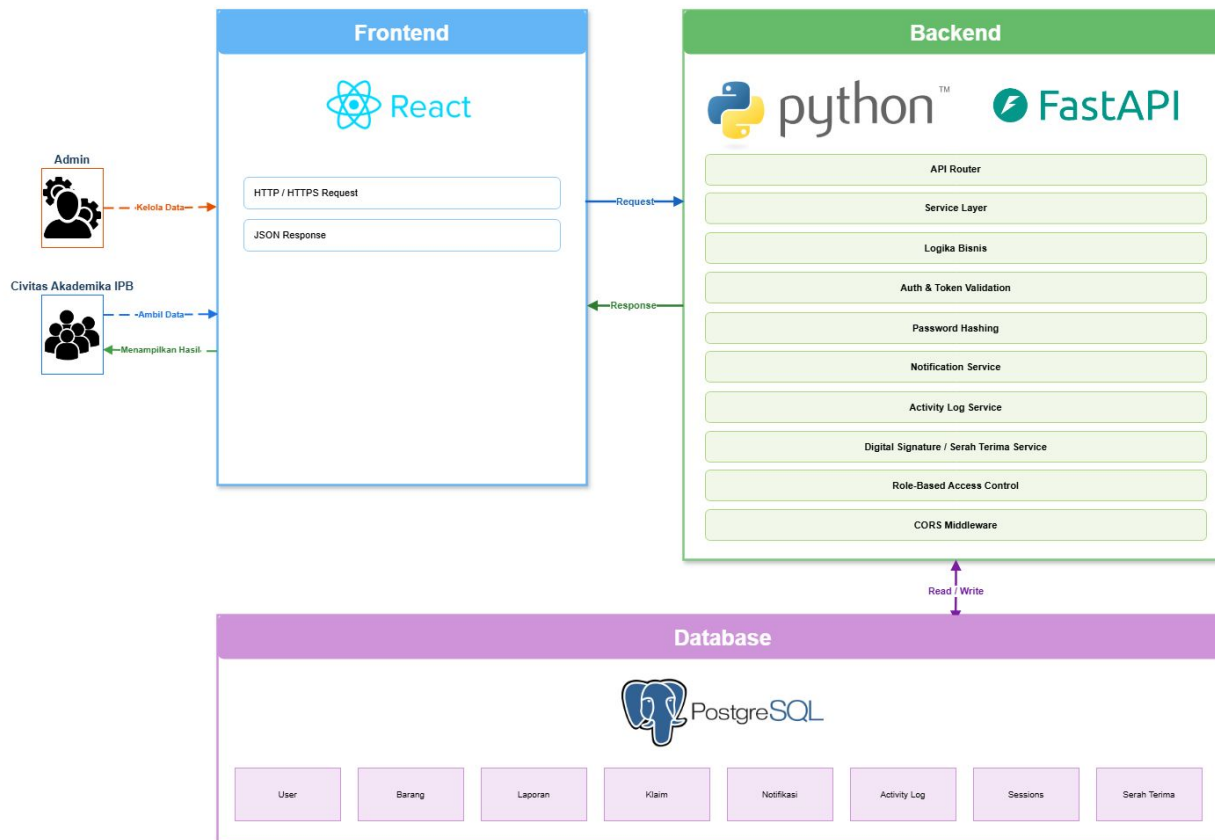
Kebutuhan Sistem

No	Sistem	Detail
1	Confidentiality	Melindungi data user, laporan, klaim, token, notifikasi, dan dokumen serah terima.
2	Integrity	Memastikan status barang, laporan, klaim, dan dokumen serah terima tidak dimanipulasi.
3	Availability	Sistem harus tetap dapat diakses civitas dan admin untuk proses lost and found.
4	Authentication	Login menggunakan kredensial dan token/JWT.
5	Authorization	Akses dibatasi berdasarkan role civitas dan admin.
6	Accountability	Aktivitas penting admin dicatat melalui activity log.



Desain Keamanan

Web Application Architecture — NEMU IPB



Data at Rest: PostgreSQL menyimpan data user, barang, laporan, klaim, notifikasi, activity log, dan serah terima.

Password disimpan sebagai password_hash, bukan plaintext.

Catatan/verifikasi dan dokumen serah terima tertentu dienkripsi dengan Fernet melalui FERNET_KEY.

Data in Transit: production direkomendasikan menggunakan HTTPS.

Key Management: SECRET_KEY, FERNET_KEY, DATABASE_URL, dan konfigurasi penting disimpan di environment variable.

Backend memiliki Auth, RBAC, Hashing, Activity Log, Notification, dan Signature Service.



Implementasi Authentication

```
graph TD; A[Login] --> B[User login memakai username yang dipetakan menjadi email @apps.ipb.ac.id.]; B --> C[Password diverifikasi terhadap password_hash menggunakan Passlib bcrypt.]; C --> D[Login sukses menghasilkan access token JWT dengan user_id, username, role, dan expiry.]; D --> E[Endpoint protected memakai HTTPBearer dan fungsi get_current_user.]; E --> F[MFA belum diimplementasikan dan menjadi rekomendasi pengembangan.];
```

The diagram illustrates the login process flow, starting with a 'Login' header. The process involves a user logging in with a username mapped to an email address, password verification using bcrypt, successful login resulting in a JWT token, and the use of HTTPBearer for protected endpoints. A final note indicates that MFA is not yet implemented and is a recommendation for future development.

Login

User login memakai username yang dipetakan menjadi email @apps.ipb.ac.id.

Password diverifikasi terhadap password_hash menggunakan Passlib bcrypt.

Login sukses menghasilkan access token JWT dengan user_id, username, role, dan expiry.

Endpoint protected memakai HTTPBearer dan fungsi get_current_user.

MFA belum diimplementasikan dan menjadi rekomendasi pengembangan.

User login memakai username yang dipetakan menjadi email @apps.ipb.ac.id.

Password diverifikasi terhadap password_hash menggunakan Passlib bcrypt.

Login sukses menghasilkan access token JWT dengan user_id, username, role, dan expiry.

Endpoint protected memakai HTTPBearer dan fungsi `get_current_user`.

MFA belum diimplementasikan dan menjadi rekomendasi pengembangan.

```
{
  "message": "Login berhasil",
  "access_token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjoxLCJ1c2VybmFtZSI6IkJ1ZGkgU2FudG9zbyIsInJvbGUiOiJjaXZpdGFzIiwiaXhwIjoxNzgwNDI1MzM1fQ.U20qVC_1SL1IBvceOP8q9LQowLcncWS-EkuLmyRt2eY",
  "token_type": "bearer",
  "user": {
    "user_id": 1,
    "username": "Budi Santoso",
    "email": "budisantoso@apps.ipb.ac.id",
    "role": "civitas"
  }
}
```





Implementasi Authorization

Sistem menggunakan Role-Based Access Control: civitas dan admin.

Civitas dapat membuat laporan, melihat barang, klaim, dropoff, dan melihat notifikasi.

Admin dapat memverifikasi laporan, verifikasi klaim/dropoff, melihat dashboard, activity log, dan riwayat serah terima.

Endpoint admin menggunakan validasi token dan pengecekan role melalui `ensure_admin`.

Endpoint serah terima membatasi akses hanya untuk admin atau pemilik data.

Mencegah broken access control.

```
"user_id": 3,  
"username": "Admin IPB",  
"email": "admin@apps.ipb.ac.id",  
"role": "admin"  
}  
}
```

```
"user_id": 1,  
"username": "Budi Santoso",  
"email": "budisantoso@apps.ipb.ac.id",  
"role": "civitas"  
}  
}
```




Implementasi Accounting

User/Admin melakukan aksi pada sistem

Sistem mencatat aktivitas perubahan

Mencatat User ID, Role, Action, Resource, Timestamp

Menyimpan Activity Log ke database

Riwayat aktivitas tersedia untuk audit

Mendukung Akuntabilitas dan Non-Repudiation

Log Akun Admin Masuk				
Menampilkan akun admin yang sedang aktif pada sesi ini.				
Admin	Email	Peran	Waktu Masuk	Status
A Admin 1 ID: 3	admin1@apps.ipb.ac.id	Admin	3 Jun 2026, 00:29	Sedang Masuk

Daftar Admin			
Akun admin yang terdaftar.			
Cari admin...			
Nama	Email	No HP	Status
A Admin 1 ID: 3	admin1@apps.ipb.ac.id	081234567801	Aktif
A Admin 2 ID: 4	admin2@apps.ipb.ac.id	081234567800	Aktif

```
{
  "detail": [
    {
      "loc": [
        "string",
        0
      ],
      "msg": "string",
      "type": "string"
    }
  ]
}
```



Implementasi Kriptografi

AES-128 (Fernet)

Enkripsi Simetris

Enkripsi Data

Digunakan pada:

Field sensitif
di database

JWT

Enkripsi Asimetris

Authentication

Digunakan pada:

SECRET_KEY, algoritma
default HS256, dan expiry
token.

SHA-256

Cryptographic Hash

Document Hashing

Digunakan pada:

dokumen serah terima
menghasilkan
dokumen_hash

RSA Digital Signature

Autentikasi Dokumen

Serah Terima

Digunakan pada:

menandatangani hash
dokumen dan verifikasi
dengan public key.

HTTPS / TLS

Secure Transport

Komunikasi Aman

Digunakan pada:

REST API
production

Password Hashing

Bcrypt

Mengamankan
Password

Digunakan pada:

Password disimpan dalam
format bcrypt pada
database



Hasil Pengujian

① Functional Testing

Test ID	Skenario	Expected Result	Status
SEC-AUTH-01	Login valid menghasilkan token	Token + data user dikembalikan	✓ Berhasil
SEC-CLAIM-01	Klaim barang dengan laporan kehilangan sendiri	Klaim dibuat, status diproses	✓ Berhasil
SEC-DROPOFF-02	Verifikasi kode dropoff memperbarui status	Status laporan selesai, barang tersedia	✓ Berhasil

② Security Testing

Test ID	Skenario	Expected Result	Status
SEC-AUTH-02	Login dengan password salah	Muncul pesan password salah	✓ Berhasil
SEC-TOKEN-02	Endpoint dipanggil dengan token palsu	Request ditolak (401/403)	✓ Berhasil

③ Authorization Testing

Test ID	Skenario	Expected Result	Status
SEC-AUTHZ01	Civitas akses dashboard admin	UI menolak, tidak ada tampilan admin	✓ Berhasil
SEC-AUTHZ02	Civitas menyetujui/menolak laporan	Menu verifikasi tidak tampil, status tak berubah	✓ Berhasil

④ API Testing

Test ID	Skenario	Expected Result	Status
SEC-API-01	Endpoint protected tanpa token	Response 401/403, data tidak dikirim	✓ Berhasil
SEC-API-02	Endpoint admin diakses civitas	Response 403 Forbidden	✓ Berhasil

⑤ CORS & HTTPS Testing

Test ID	Skenario	Expected Result	Status
SEC-TOKEN-01	Request tanpa Authorization header	Response 401, data tidak dikembalikan	✓ Berhasil
(CORS)	Origin frontend tidak terdaftar di CORS	Request diblokir browser (production)	✓ Berhasil

⑥ Integration Testing

Test ID	Skenario	Expected Result	Status
SEC-SIGN-01	Klaim valid diterima → dokumen serah terima dibuat	Record serah terima terbuat di DB	✓ Berhasil
SEC-LOG-01	Admin setuju laporan → masuk activity log	Log baru tercatat di DB	✓ Berhasil
SEC-HASH-01	Kolom password di tabel users	Tersimpan password_hash, bukan plaintext	✓ Berhasil

Analisis Kinerja

endpoint /barang

```
Run 1 - Status: 200, Time: 1.666232s, Size: 1211367 bytes
Run 2 - Status: 200, Time: 1.658434s, Size: 1211367 bytes
Run 3 - Status: 200, Time: 0.867933s, Size: 1211367 bytes
Run 4 - Status: 200, Time: 1.477235s, Size: 1211367 bytes
Run 5 - Status: 200, Time: 1.686946s, Size: 1211367 bytes
```

endpoint admin/laporan

```
Run 1 - Status: 200, Time: 1.698594s, Size: 1211714 bytes
Run 2 - Status: 200, Time: 1.655352s, Size: 1211714 bytes
Run 3 - Status: 200, Time: 1.210591s, Size: 1211714 bytes
Run 4 - Status: 200, Time: 1.687841s, Size: 1211714 bytes
Run 5 - Status: 200, Time: 1.635106s, Size: 1211714 bytes
```

Sebelum implementasi keamanan, akses lebih sederhana, tetapi risiko unauthorized access dan manipulasi data lebih tinggi. Setelah implementasi keamanan, ada overhead kecil dari validasi token, hashing password, enkripsi, dan activity log, sehingga response time naik sedikit (~1,68 s dibanding ~1,47 s) dan ukuran data bertambah minimal, tetapi confidentiality, integrity, dan auditability sistem meningkat signifikan.

Kesimpulan

Berdasarkan hasil analisis, tujuan perancangan keamanan pada sistem NEMU IPB telah tercapai melalui penerapan dasar keamanan aplikasi web, seperti authentication, authorization, password hashing, token validation, input validation, activity log, RBAC, serta pengamanan dokumen serah terima melalui hashing dan digital signature. Namun, sistem masih memiliki keterbatasan, seperti belum adanya MFA, rate limiting yang lebih kuat, login history, monitoring keamanan, backup terstruktur, serta pengujian keamanan lanjutan. Oleh karena itu, pengembangan berikutnya dapat difokuskan pada penguatan session management, pembatasan CORS production, penerapan MFA, monitoring aktivitas mencurigakan, backup berkala, dan security testing agar sistem lebih aman, stabil, dan siap digunakan pada lingkungan production.



IPB University
— Bogor Indonesia —

Inspiring Innovation with Integrity
in Agriculture, Ocean and Biosciences for a Sustainable World